

 Case Metadata

Field	Value
Case ID:	CS-2025-003
Case Type:	Microsoft Exchange RCE Vulnerability
Reported by:	Splunk SIEM
Analyst:	Ali YILMAZ
Date:	2025-10-05
Severity:	High
Status:	Closed
Environment:	Production

 Detection Rule Details

Rule Name: Microsoft Exchange RCE Vulnerability

Rule Description: The attacker for this vulnerability could target the server accounts in an arbitrary or remote code execution. As an authenticated user, the attacker could attempt to trigger malicious code in the context of the server's account through a network call.

Correlation Rule (SPL):

```
(index=wineventlog process_name=w3wp.exe EventCode IN ("1","4688") (process=*echo* AND process IN ("ipconfig","quser","whoami","c:","cd","dir","[E]","[S]"))) OR (index=fortinet (125.212.220.48 OR 5.180.61.17 OR 47.242.39.92 OR 61.244.94.85 OR 86.48.6.69 OR 86.48.12.64 OR 94.140.8.48 OR 94.140.8.113 OR 103.9.76.208 OR 103.9.76.211 OR 104.244.79.6 OR 112.118.48.186 OR 122.155.174.188 OR 125.212.241.134 OR 185.220.101.182 OR 194.150.167.88 OR 212.119.34.11 OR 206.188.196.77 OR 137.184.67.33) OR (autodiscover subtype=ips) ) OR (index=wineventlog (pxh4HG1v.ashx OR RedirSuiteServiceProxy OR Xml.ashx OR errorEE.aspx OR Dll.dll) OR (c838e77afe750d713e67ffeb4ec1b82ee9066cbe21f11181fd34429f70831ec1,65a002fe655dc1751add167cf00adf284c080ab2e97cd386881518d3a31d27f5,b5038f1912e7253c7747d2f0fa5310ee8319288f818392298fd92009926268ca,c838e77afe750d713e67ffeb4ec1b82ee9066cbe21f11181fd34429f70831ec1,be07bd9310d7a487ca2f49bcdaafb9513c0c8f99921fdf79a05eaba25b52d257,074eb0e75bb2d8f59f1fd571a8c5b76f9c899834893da6f7591b68531f2b5d82,45c8233236a69a081ee390d4faa253177180b2bd45d8ed08369e07429ffbe0a9,9ceca98c2
```

b24ee30d64184d9d2470f6f2509ed914dafb87604123057a14c57c0,29b75f0db3006440651c6342dc3c0672210cfb339141c75e12f6c84d990931c3,c8c907a67955bcdf07dd11d35f2a23498fb5ffe5c6b5d7f36870cf07da47bff2,76a2f2644cb372f540e179ca2baa110b71de3370bb560aca65dcddb7da3701e)) OR (index=apache autodiscover.json earliest=-7d) OR (index=msexchange autodiscover.json NOT "autodiscover.json Email=" python)

| eval url = coalesce(url,Email,"")

Triggered Field(s):

T1210 — Exchange RCE scan from 66.175.211.202 → 10.11.12.240:443 (Nmap Script Scanner)

Detection Summary

The attacker for this vulnerability could target the server accounts in an arbitrary or remote code execution. As an authenticated user, the attacker could attempt to trigger malicious code in the context of the server's account through a network call.

Analyst Investigation

- **Source IP:** 66.175.211.202 detected with signature *Nmap.Script.Scanner*.
Checked on **VirusTotal**, **AbuseIPDB**, and **CyberChef**.
 - VirusTotal → flagged for scanning activity.
 - AbuseIPDB → reported for port scanning.
 - CyberChef → decoded payload shows no malicious commands.
- **Destination:** Internal Exchange Server 10.11.12.240 via HTTPS (443).
Traffic was **dropped by Fortinet**, no exploit execution observed.
- **User-Agent:** Mozilla/5.0 (compatible; Nmap Scripting Engine) → indicates automated scan.
- **Correlation Rule:** "Threat – Microsoft Exchange RCE Vulnerability."
- **Result: False Positive / Benign scan attempt.**
No system impact detected.

Decision:  False Positive (benign reconnaissance attempt)

Investigation Steps:

- Reviewed Splunk alert for **T1210 – Exploitation of Remote Services** (Microsoft Exchange RCE).
- Identified **source IP 66.175.211.202** targeting internal Exchange server 10.11.12.240 on port 443.

- Checked IP reputation on **VirusTotal** and **AbuseIPDB** → flagged for **scanning/recon activity**.
- Decoded HTTP request in **CyberChef** → no malicious payload or command detected.
- Verified **Fortinet logs** → traffic **blocked (action=dropped)**, no exploit executed.
- Correlated with **Exchange event logs** → no suspicious PowerShell or IIS entries found.
- Conducted SIEM search for repeated connections from the same source → none found.
- Classified event as **False Positive (benign external scan)**.

MITRE ATT&CK Mapping

T1210 - Exploitation of Remote Services Mitre Attack

 False Positive (benign reconnaissance attempt)

Recommended Actions

- Block source IP (66.175.211.202) on the perimeter firewall and update threat-intel blocklists.
- Search SIEM for any other activity from the same IP or subnet within the last 7 days.
- Check Exchange Server (10.11.12.240) for suspicious IIS or PowerShell logs around the alert time.
- Verify patch level of Microsoft Exchange — ensure all RCE-related CVEs (e.g., ProxyShell, ProxyNotShell) are remediated.
- Notify Tier-2 / Threat-Intel team to enrich IOC and monitor for recurrence.
- Document the case in the incident tracker and attach VirusTotal, AbuseIPDB, and CyberChef evidence.
- Maintain monitoring for similar exploitation attempts targeting external-facing services.

Organizational / HR Actions

- **Notify IT Operations** to confirm Exchange server patch compliance and configuration review.
- **Inform Security Management** of the confirmed external exploitation attempt for awareness reporting.
- **Update internal security bulletin** or awareness board to highlight recent Exchange-related RCE scans.

- **No disciplinary or HR measures** required — activity originated externally, not from an internal user.
- **Coordinate with Threat-Intel team** to share IOC (66.175.211.202) across all business units.

Business Impact

- The attack targeted a **critical business asset** (Microsoft Exchange Server), which handles internal and external communication.
- **No operational disruption** occurred; the exploit attempt was successfully blocked by the firewall.
- If successful, the attack could have led to **unauthorized access, email data exposure, or privilege escalation** within the corporate network.
- The event demonstrates the importance of maintaining **timely patching** and **continuous monitoring** for exposed services.
- **Overall impact:** *Low (attempt blocked)* — but **potential risk: High** due to the asset's sensitivity.

Evidence in Case

- **Splunk Incident Review screenshot** showing triggered alert (*Microsoft Exchange RCE – T1210*).
- **Raw Fortinet log extract** confirming action=dropped and signature Nmap.Script.Scanner.
- **VirusTotal report** — Source IP 66.175.211.202 flagged for scanning/recon activity.
- **AbuseIPDB report** — IP reported multiple times for port scanning and exploit attempts.
- **CyberChef analysis** — Decoded HTTP payload shows no malicious command execution.
- **Exchange IIS & PowerShell logs** — No exploit indicators or post-compromise activity found.

Incident Review

Search...Show ChartsHide Filters

Saved filters

Tag

Urgency

Status

Owner

Security Domain

Type

Search Type

Time or Associations

Select...

Add tags...

Select...

Select...

Select...

Select...

Select...

Correlation S...

Select...

Associations

Associations

Short ID

YiPiB

Save new filters

Update

Clear all

Submit

Associations: Short ID: YiPiB

1 Notables

Unselect all | Edit Selected | Edit All Matching Events (1) | Add Selected to Investigation

20 per pageRefresh

	Title	Risk Object	Risk Score	Risk Events	Type	Time	Disposition	Security Domain	Urgency	Status	Owner	Actions
☐	Microsoft Exchange RCE Vulnerability	-	-	-	Notable	Wed, Oct 1, 2025 11:15 PM	Undetermined	Threat	Low	New	unassigned	

Description:

The attacker for this vulnerability could target the server accounts in an arbitrary or remote code execution. As an authenticated user, the attacker could attempt to trigger malicious code in the context of the server's account through a network call.

Additional Fields	Value	Action
Action	blocked	
Annotations	T1210	
Annotation Framework	mitre_attack	
Application	HTTP	
Category	Nmap.Script.Scanner	
Destination	10.11.12.240	
Destination IP Address	10.11.12	
Destination Port	443	
Destination Zone	lan	
Direction	outgoing	
Device	CNL	
File Path	autodiscover.cybernowlabs.com/	
HTTP User Agent	Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)	
Intrusion Detection Type	network	
Host	10.11.254.25	
Original Splunk Source	/data/log/splunk/syslog/10.11.254/splink-collector-2025-10-01-22.log	
Product	Firewall	
Product Version	50	
Internet Protocol	6	
Risk Score	240	
Session Identifier	8032879	
Severity	low	
Signature	Nmap.Script.Scanner	
Signature Identifier	45360	
Source	66.175.211.202	
Source IP Address	66.175.211.202	
Source Port	38090	
Source Zone	wan	
Transport Protocol	tcp	
Type	utm	
URL	autodiscover.cybernowlabs.com/	
Vendor	Fortinet	
Vendor/Product	Fortinet Firewall	

Event Details:

event_id	FC5F1EF-0E6E-4C54-902C-4CB2803883E5@notable@ee819e3ae026880f5fd98cfad7b9624f
event_hash	ee819e3ae026880f5fd98cfad7b9624f
eventtype	modnotable_results
	notable
Short ID	YiPiB

Related Investigations:

Currently not investigated.

Correlation Search:

Threat - Microsoft Exchange RCE Vulnerability - Rule

History:

View all review activity for this Notable Event

Contributing Events:

Go Events

Original Event:

```
= "signature" level="alert" vd="root" severity="low" srcip=66.175.211.202 srccountry="United States" dstip=10.1.1.12 dstcountry="Reserved" srcintf="wan1" srcintfrole="wan" dstintf="internal" dstintfrole="lan" sessionid=8032879 action="dropped" proto=6 service="HTTP" policyid=17 poluid="92e03710-af68-51ea-aab7-414e06510c5c" policytype="policy" attack="Nmap.Script.Scanner" srcport=38090 dstport=443 hostname="autodiscover.cybernowlabs.com" url="/" agent="Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)" httpmethod="GET" direction="outgoing" attackid=45360 profile="protect_http_server" ref="http://www.fortinet.com/ids/VID45360" incidentserialno=97830273 msg="tools: Nmap.Script.Scanner" crscore=5 craction=32768 crlevel="low"
```

View original event

Adaptive Responses:

Response	Mode	Time	User	Status
Notable	saved	2025-10-01T23:15:18-0400	admin	success

View Adaptive Response Invocations

Next Steps:

No next steps defined.

You do not have the necessary permissions to edit this search.

Correlation Search

Search Name

Microsoft Exchange RCE Vulnerability

App

CNL Admin

UI Dispatch Context

Enterprise Security

Description

The attacker for this vulnerability could target the server accounts in an arbitrary or remote code execution. As an authenticated user, the attacker could attempt to trigger malicious code in the context of the server's account through a network call.

Mode

GuidedManual

Search

(index=wineventlog process_name=w3wp.exe EventCode IN ("1","4688")) (process==echo* AND process IN ("ipconfig","quser","whoami","::","cd","dir","[E]","[S]")) OR (index=fortinet (125.212.220.48 OR 5.180.61.17 OR 47.242.39.92 OR 61.244.94.85 OR 86.48.6.6 OR 86.48.12.64 OR 94.140.8.48 OR 94.140.8.113 OR 103.9.76.208 OR 103.9.76.211 OR 104.244.79.6 OR 112.118.48.186 OR 122.155.1.188 OR 125.212.241.134 OR 185.220.101.182 OR 194.150.167.88 OR 212.119.34.11 OR 206.188.196.77 OR 137.184.67.33) OR (autodiscover subtype=ips)) OR (index=wineventlog (pxh4HG1v.ashx OR RedirSuiteServiceProxy Xml.ashx OR errorEE.aspx OR D.dll) OR (c838e77afe750d713e67ffeb4ec1b82ee9066cbe21f11181fd34429f70831ec1,65a002fe655dc1751add167cf00adf284c080ab2e97cd386881518d3a31d27f5,b5038f1912e7253c7747d2f0fa5310ee8319288f818392298fd92009926268ca,c838e77afe750d713e67ffeb4ec1b82ee9066cbe21f11181fd34429f70831ec1,be07bd9310d7a487ca2f49bcdafbf9513c0c8f99921fdf79a05eaba25b52d257,074eb0e75bb2d8f59f1fd571a8c5b76f9c899834893da6f7591b68531f2b5d82,45c8233236a69a081ee390d4faa253177180b2bd45d8ed08369e07429ffbe0a9,9ceca98c2b24ee30d64184d9d2470f6f2509ed914dafb87604123057a14c57c0,29b75f0db3006440651c6342dc3c0672210cfb339141c75e12f6c84d990931c3,c8c907a67955bcdff07dd11d35f2a23498fb5ffe5c6b5d7f36870cf07da47bfff2,76a2f2644cb372f540e179ca2baa110b71de3370bb560aca65dcd8bd7da3701e)) OR (index=apache_autodiscover.json earliest=-7d) OR (index=msexchange_autodiscover.json NOT "autodiscover.json Email=" python) | eval url = coalesce(url,Email,"")

splunkenterpriseApps

Ali Yilmaz998MessagesSettingsActivityHelpFind

Security PostureIncident ReviewInvestigationsSecurity IntelligenceSecurity DomainsCloud SecurityAuditSearchConfigureEnterprise Security

New Search

Save AsCreate Table ViewClose

index="fortinet" 66.175.211.202 | stats dc(dstport) values(dstport) by _time dest_ip action

Date time rangeFind

23 events (10/1/25 10:05:00.000 PM to 10/1/25 11:05:00.000 PM)No Event SamplingJob|||Smart Mode

EventsPatternsStatistics (7)Visualization

20 Per PageFormatPreview

_time	dest_ip	action	dc(dstport)	values(dstport)
2025-10-01 22:36:25	96.73.98.188	blocked	0	
2025-10-01 22:36:28	96.73.98.188	blocked	3	80808088
2025-10-01 22:36:29	96.73.98.188	blocked	9	387263170808080098080808884438447
2025-10-01 22:36:38	10.1.1.12	blocked	1	443
2025-10-01 22:37:18	96.73.98.188	blocked	1	443
2025-10-01 22:37:52	10.1.1.12	blocked	1	443
2025-10-01 22:38:40	96.73.98.188	blocked	1	443

Job ▾ || ■ ↻ 🔍 ⬇ ⚡ Smart Mode ▾

Job Smart Mode [illegible]

66.175.211.202

3

/ 95

Community Score

-13

3/95 security vendors flagged this IP address as malicious

Reanalyze

Similar

More

66.175.211.202 (66.175.208.0/20)

AS 63949 (Akamai Connected Cloud)

US

Last Analysis Date

2 days ago

DETECTION

DETAILS

RELATIONS

COMMUNITY 6

Security vendors' analysis

Do you want to automate checks?

ArcSight Threat Intelligence	Malware	Criminal IP	Malicious
SOCradar	Malware	AlphaSOC	Suspicious
CyRadar	Suspicious	Gridinsoft	Suspicious
Abusix	Clean	Acronis	Clean
ADMINUSLabs	Clean	AILabs (MONITORAPP)	Clean
AlienVault	Clean	Antiy-AVL	Clean

AbuseIPDB » 66.175.211.202

Check an IP Address, Domain Name, or Subnet
e.g. 178.193.246.50, microsoft.com, or 5.188.10.0/24

66.175.211.202

CHECK

feedback

66.175.211.202 was found in our database!

This IP was reported 169 times. Confidence of Abuse is 88%?

88%

ISP: Linode
Usage Type: Data Center/Web Hosting/Transit
ASN: AS63949
Hostname(s): 66-175-211-202.linodeusercontent.com
Domain Name: linode.com
Country: United States of America
City: Cedar Knolls, New Jersey

IP info including ISP, Usage Type, and Location provided by IPinfo. Updated biweekly.

REPORT 66.175.211.202

WHOIS 66.175.211.202

IP Abuse Reports for 66.175.211.202:

This IP address has been reported a total of 169 times from 33 distinct sources. 66.175.211.202 was first reported on March 31st 2024, and the most recent report was 2 hours ago.

Recent Reports: We have received reports of abusive activity from this IP address within the last week. It is potentially still actively engaged in abusive activities.

Reporter	IoA Timestamp (UTC)	Comment	Categories
 sdos.es	2025-10-05 04:27:42 (5 hours ago)	"Found User-Agent associated with security scanner - M atched Data: nmap scripting engine found withi ... show more	Web App Attack
 security.rdmc.fr	2025-10-05 00:53:39 (8 hours ago)	Port Scan Attack proto:TCP src:38419 dst:631	Port Scan
 Rizzy	2025-10-04 22:49:06 (11 hours ago)	Multiple WAF Violations	Brute-Force Web App Attack
 Anonymous	2025-10-04 18:18:00 (15 hours ago)	Aggressive web scan	Web App Attack
 ThreatBook.io	2025-10-02 22:34:25 (2 days ago)	ThreatBook Intelligence: vpn_proxy.Spam more details on https://threatbook.io/ip/66.175.211.202<br / ... show more	Web App Attack
 Anonymous	2025-10-02 10:03:00 (2 days ago)	Nmap Scripting Engine	Web App Attack
 sdos.es	2025-10-02 09:14:55 (3 days ago)	"Found User-Agent associated with security scanner - M atched Data: nmap scripting engine found withi ... show more	Web App Attack
 gu-alvarez	2025-10-02 07:05:05 (3 days ago)	Nmap.Script.Scanner	Port Scan
 Rizzy	2025-10-01 20:33:18 (3 days ago)	Multiple WAF Violations	Brute-Force Web App Attack
 Cyber Crusader	2025-10-01 19:48:56 (3 days ago)	Hundreds of Attempts (at least) to Connect to and Acces s Firewall Ports	Port Scan Hacking Brute-Force
 Anonymous	2025-10-01 18:17:43 (3 days ago)	Aggressive web scan	Web App Attack
 ThreatBook.io	2025-09-29 22:52:51 (5 days ago)	ThreatBook Intelligence: vpn_proxy.Spam more details on https://threatbook.io/ip/66.175.211.202<br / ... show more	Web App Attack
 gu-alvarez	2025-09-29 07:05:03 (6 days ago)	Nmap.Script.Scanner	Port Scan
 sdos.es	2025-09-29 04:21:16 (6 days ago)	"Found User-Agent associated with security scanner - M atched Data: nmap scripting engine found withi ... show more	Web App Attack
 Cyber Crusader	2025-09-29 03:47:55 (6 days ago)	Hundreds of Attempts (at least) to Connect to and Acces s Firewall Ports	Port Scan Hacking Brute-Force

Showing 1 to 15 of 169 reports

< 1 2 3 4 5 6 7 8 9 10 11 12 >

Is this your IP? You may request to takedown any associated reports. We will attempt to verify your ownership. REQUEST TAKEDOWN

Recently Reported IPs:

 176.224.5.215
 145.239.89.124
 138.0.69.5
 200.115.70.63
 197.248.8.33

 183.226.203.20
 190.104.242.100
 152.201.218.47
 45.170.214.50
 181.29.164.48

 45.168.181.91
 192.95.255.168
 191.240.231.108
 5.31.218.244
 103.181.110.118

 37.142.100.254
 122.117.201.170
 91.75.112.224
 160.19.246.43
 179.35.38.156



TECHNIQUES

Exploitation of Remote Services ▲

Internal Spearphishing

Lateral Tool Transfer

Remote Service ▾

Session Hijacking

Remote Services ▾

Replication Through

Removable Media

Software Deployment

Tools

Taint Shared Content

Use Alternate

Authentication

Material

Collection ▾

Command and Control ▾

Exploitation of Remote Services

Adversaries may exploit remote services to gain unauthorized access to internal systems once inside of a network. Exploitation of a software vulnerability occurs when an adversary takes advantage of a programming error in a program, service, or within the operating system software or kernel itself to execute adversary-controlled code. A common goal for post-compromise exploitation of remote services is for lateral movement to enable access to a remote system.

An adversary may need to determine if the remote system is in a vulnerable state, which may be done through [Network Service Discovery](#) or other Discovery methods looking for common, vulnerable software that may be deployed in the network, the lack of certain patches that may indicate vulnerabilities, or security software that may be used to detect or contain remote exploitation. Servers are likely a high value target for lateral movement exploitation, but endpoint systems may also be at risk if they provide an advantage or access to additional resources.

There are several well-known vulnerabilities that exist in common services such as SMB^[1] and RDP^[2] as well as applications that may be used within internal networks such as MySQL^[3] and web server services.^{[4][5]} Additionally, there have been a number of vulnerabilities in VMware vCenter installations, which may enable threat actors to move laterally from the compromised vCenter server to virtual machines or even to ESXi hypervisors.^[6]

Depending on the permissions level of the vulnerable remote service an adversary may achieve [Exploitation for Privilege Escalation](#) as a result of lateral movement exploitation as well.

ID: T1210

Sub-techniques: No sub-techniques

① **Tactic:** Lateral Movement① **Platforms:** ESXi, Linux, Windows, macOS**Contributors:** ExtraHop**Version:** 1.2**Created:** 18 April 2018**Last Modified:** 15 April 2025[Version Permalink](#)